

安全事件响应与复盘手册

企业制度综合验收样本文档

第一章 事件定义与分级

安全事件是指可能影响系统可用性、数据机密性、完整性或业务连续性的异常，包括账号被盗、恶意软件、异常下载、生产服务不可用、钓鱼邮件、敏感数据误发和第三方服务风险。事件按影响分为 P1 至 P4：P1 影响核心生产服务、大量客户数据或监管义务；P2 影响重要业务或存在明确扩散风险；P3 影响有限且可由单个团队处理；P4 为一般告警或已证实误报。初始分级应宁高勿低，并在调查后调整。

第二章 首报与响应时限

任何员工发现可疑事件后，应立即停止可能扩大影响的操作，保留时间、账号、设备、文件名称、错误截图和相关沟通记录。P1 和 P2 事件的首报目标为发现后 30 分钟内，P3 事件为 4 小时内，P4 事件应在当日登记。首报渠道为安全事件工单和应急电话；不得只在私人聊天群中报告。事件经理负责建立协作频道、明确负责人、每 30 分钟同步 P1 进展，并记录所有关键决定。

第三章 隔离、取证与恢复

未经事件经理同意，不得重启、格式化、删除日志或覆盖可能的证据。技术负责人应优先采取可逆隔离措施，例如禁用账号、撤销令牌、限制网络访问、切换只读模式或下线受影响服务。取证人员应保存日志快照、哈希值、访问记录和时间线。恢复生产前必须明确根因假设、修复措施、回滚方案和验证指标；对于 P1 事件，恢复决策需由事件经理、业务负责人和技术负责人共同确认。

第四章 沟通与外部披露

对内沟通应使用事件编号和统一事实表，避免传播未经证实的个人判断。向客户、监管机构、媒体或合作伙伴披露信息只能由法务、合规和指定发言人执行。任何员工不得在社交媒体、个人博客或未经批准的客户群中描述事件细节。若事件涉及个人信息，隐私负责人应评估通知义务、影响范围、受影响主体和补救措施。

第五章 复盘与改进

事件关闭后 5 个工作日内，事件经理应组织复盘，形成时间线、影响评估、根因、处置有效性、未解决风险和改进项。改进项必须有负责人和完成日期；高优先级问题在下一管理例会上跟踪。复盘的目的是改进系统和流程，不以追责替代事实分析；但对故意隐瞒、绕过控制或伪造记录的行为，应另行提交合规调查。

第六章 常见问答

问：发现账号可能泄露时第一步是什么？答：停止可疑操作并立即报告，同时保留证据。问：P1 首报目标多久？答：30 分钟内。问：谁可以对外说明事件？答：法务、合规和指定发言人。问：为什么不能直接重启受影响主机？答：可能破坏日志和证据，应先由事件经理协调隔离和取证。